

Analisi Traffico di Rete & Incident Response

1. SINTESI DELL'ATTACCO

L'analisi del file di cattura pcap evidenzia un'attività di ricognizione di rete (Port Scanning) diretta verso l'infrastruttura. L'attaccante ha mappato i servizi attivi prima di tentare potenziali azioni di exploitation.

ATTIVITÀ RILEVATA

Port Scanning

Nmap TCP Connect Scan

IP ATTACCANTE (SOURCE)

192.168.200.100

Macchina Kali Linux

IP TARGET (VITTIMA)

192.168.200.150

Metasploitable 2

2. INDICATORI DI COMPROMISSIONE (IOC)

ELEMENTO	VALORE / DETTAGLIO	LIVELLO RISCHIO
IP Sorgente Sospetto	192.168.200.100	ALTO
Pattern Traffico TCP	Volume elevato di pacchetti [SYN] inviati a sequenza rapida verso multiple porte TCP.	ALTO
Traffico UDP Broadcast	Pacchetti Broadcast NetBIOS / BROWSER diretti a 192.168.200.255 (Host Announcement).	MEDIO

3. METODOLOGIA DI ANALISI E FILTRI WIRESHARK

Per isolare il traffico malevolo e giungere a conclusioni certe, sono stati applicati i seguenti filtri di analisi:

A. Isolamento del Traffico del Target:

```
ip.addr == 192.168.200.150
```

Elimina il traffico di background non pertinente e isola l'interazione tra l'attaccante e la vittima.

B. Identificazione del Servizio di Annuncio (UDP/NetBIOS):

```
browser || udp.port == 138
```

Isola il pacchetto UDP *Host Announcement* (METASPLOITABLE), confermando il servizio Samba attivo e l'IP del target.

C. Analisi della Scansione TCP (Isolamento Porta Aperta 80):

```
ip.addr == 192.168.200.150 && tcp.port == 80
```

Consente di osservare lo scambio di pacchetti sulla porta aperta 80 HTTP per determinare il tipo di scansione.

4. CONCETTI CRUCIALI E DEDUZIONI TECNICHE

Dall'analisi di dettaglio della sequenza dei pacchetti sulla porta 80 emerge la seguente comunicazione:

- 192.168.200.100 → 192.168.200.150 : [SYN] (Richiesta di connessione)
- 192.168.200.150 → 192.168.200.100 : [SYN, ACK] (Porta 80 aperta e pronta)

3. 192.168.200.100 → 192.168.200.150 : **[ACK]** (Completamento 3-Way Handshake)
4. 192.168.200.100 → 192.168.200.150 : **[RST, ACK]** (Chiusura immediata della connessione)

Dimostrazione della Tecnica Nmap (-sT vs -sS):

La presenza del pacchetto **[ACK]** (passo 3) inviato dall'attaccante dimostra il completamento completo del *Three-Way Handshake* TCP tramite le API del sistema operativo.

Conclusione: Si tratta di una **TCP Connect Scan (nmap -sT)**. In una Stealth SYN Scan (-sS), l'attaccante non invia mai l'[ACK] finale, ma risponde subito con un [RST] per interrompere la connessione a metà.

Comando Nmap Ricostruito:

```
nmap -sT 192.168.200.150
```

5. TECNICHE DI MITIGAZIONE CONSIGLIATE

- **Configurazione Firewall & Rate Limiting:**

Implementare regole IPTables / UFW per limitare la frequenza dei pacchetti [SYN] in ingresso dallo stesso IP. Rispondere con DROP anziché REJECT sulle porte chiuse per mascherarle come *Filtered*.

- **Sistemi IDS/IPS (Snort / Suricata):**

Configurare regole per rilevare firme comportamentali tipiche di Nmap (elevato rate di pacchetti SYN/ACK rapidamente resettati da singoli host).

- **Disattivazione Protocolli Obsoleti:**

Disabilitare NetBIOS over TCP/IP e il servizio BROWSER/SMBv1. Questo evita l'invio di pacchetti UDP Broadcast che rivelano il nome host e la topologia di rete.